

1. Social Engineering Concepts

What is Social Engineering?

The art of convincing or manipulating people to reveal confidential information or perform actions they wouldn't normally do. It targets human weaknesses rather than technical vulnerabilities. Attackers rely on victims being unaware of the value of the information they possess or being careless in protecting it.

Information Gathering by Attackers

- Official websites (employee IDs, names, emails).
- Advertisements (products, offers).
- Blogs, forums (personal and organizational info).

Behaviors Vulnerable to Attacks (Principles of Social Engineering)

These are psychological triggers attackers exploit:

- **Authority:** People tend to obey figures of authority. (e.g., attacker pretends to be IT admin).
- **Intimidation:** Using bullying tactics to coerce victims.
- **Consensus (Social Proof):** People are influenced by what others do/like. (e.g., fake testimonials).
- **Scarcity:** Creating a feeling of urgency or limited availability. (e.g., "limited stock" offers).
- **Urgency:** Encouraging immediate action. (e.g., ransomware countdowns, "buy now" prompts).
- **Familiarity / Liking:** People are more persuaded by those they like or are familiar with. (e.g., charming smile, sweet-talk).
- **Trust:** Building a trusting relationship to extract info. (e.g., attacker poses as a "security expert").
- **Greed:** Luring targets with promises of something for nothing. (e.g., large rewards for information).

Factors that Make Companies Vulnerable

- **Insufficient Security Training:** Employees unaware of social engineering tricks.
- **Unregulated Access to Information:** Too many people having access to sensitive data.
- **Several Organizational Units:** Decentralized structure makes management difficult.
- **Lack of Security Policies:** No clear guidelines on security measures.

Why is Social Engineering Effective?

- Deals with **psychological manipulation**, not technical issues.
- Difficult to detect.
- No method guarantees complete security.

- No specific hardware/software fully defends against it.
- Relatively cheap and easy to implement.

Phases of a Social Engineering Attack (Attack Lifecycle)

1. **Research the Target Company:** Gather information (dumpster diving, website browsing, employee details).
2. **Select a Target:** Often disgruntled employees are easier to manipulate.
3. **Develop a Relationship:** Build rapport with the target.
4. **Exploit the Relationship:** Extract sensitive information.

Types of Social Engineering

 Human-based Social Engineering	• Sensitive information is gathered by interaction	Techniques:	• Impersonation • Vishing • Eavesdropping • Shoulder Surfing • Dumpster Diving	• Reverse Social Engineering • Piggybacking • Tailgating • Diversion Theft • Honey Trap	• Baiting • Bait and Switching • Quid Pro Quo • Elicitation
 Computer-based Social Engineering	• Sensitive information is gathered with the help of computers	Techniques:	• Pop-up Window • Phishing • Instant Chat Messenger • Spam Mail	• Scareware • Create Deepfake Videos • Voice Cloning	
 Mobile-based Social Engineering	• Sensitive information is gathered with the help of mobile apps	Techniques:	• Using Fake Security Apps • Publishing Malicious Apps • SMiShing (SMS Phishing)	• Repackaging Legitimate Apps • QR LJacking	

2. Human-based Social Engineering Techniques

These involve direct human interaction.

- **Impersonation:** Pretending to be someone legitimate or authorized (e.g., technician, senior executive, vendor, client, repairman).
 - **Vishing (Voice or VoIP Phishing):** Impersonation over phone/VoIP to trick victims into divulging financial or personal info.
 - **Trusted Authority Figure:** Posing as an authority (e.g., internal auditor, fire marshal).
- **Eavesdropping:** Listening to unauthorized conversations or reading others' messages (audio, video, written).
- **Shoulder Surfing:** Observing a person's computer screen or keyboard over their shoulder to gain information (passwords, PINS, account numbers).
- **Dumpster Diving:** Searching through trash for discarded confidential information (phone lists, organizational charts, emails, policy manuals).
- **Reverse Social Engineering:** Making the victim ask the attacker for help, creating a situation where the attacker becomes the "expert" that the victim trusts. (e.g., attacker creates a problem, victims seek help).

- **Piggybacking (Tailgating):** Following an authorized person into a restricted area without proper authorization.
- **Diversion Theft:** Tricking a person responsible for delivery into diverting a legitimate delivery to an unintended location.
- **Honey Trap:** Attacker targets a person online by pretending to be attractive to obtain confidential info.
- **Baiting:** Luring targets by presenting an exciting offer (e.g., infected USB drives left in public places, tempting downloads).
- **Quid Pro Quo:** Promising something for nothing in return for information (e.g., offering IT support in exchange for credentials).
- **Elicitation:** Art of extracting information by subtly prompting or engaging in seemingly innocuous conversations.
- **Bait and Switching:** Capturing victim's attention with an offer, then redirecting to a malicious link/site.

3. Computer-based Social Engineering Techniques

These rely on computers and the Internet.

- **Phishing:** Sending fraudulent emails or messages disguised as legitimate sources to trick users into revealing personal information (usernames, passwords, credit card details).
 - **Spear Phishing:** Highly targeted phishing attack aimed at specific individuals or organizations.
 - **Whaling:** Phishing attacks targeting high-profile executives (CEO, CFO).
 - **Pharmishing:** Redirecting users from legitimate websites to fake malicious websites, often through DNS cache poisoning or host file modification.
 - **Spamming:** Sending unsolicited messages to collect financial info or infect systems.
 - **Clone Phishing:** Creating a nearly identical copy of a legitimate email or website to trick users.
 - **E-wallet Phishing:** Targets e-wallet/digital wallet credentials.
 - **Tabnabbing / Reverse Tabnabbing:** Exploiting web browser tabs to trick users into entering credentials on a malicious page.
 - **Consent Phishing:** Exploiting OAuth authentication flow (e.g., Google, Facebook) to trick users into granting malicious applications access to their accounts.
 - **Search Engine Phishing:** Manipulating search engine results to redirect users to fraudulent websites.

Phishing Tools

The Social-Engineer Toolkit (SET)

The SET is an open-source Python-driven tool aimed at penetration testing around social engineering
ShellPhish

ShellPhish is a phishing tool used to phish user credentials from various social networking platforms such as Instagram, Facebook, Twitter, LinkedIn, etc.

- **Scareware:** Malware that tricks users into believing their computer is infected or at risk, prompting them to download fake security software.
- **Hoax Letters:** False alarms about viruses or security threats.
- **Chain Letters:** Messages promising free gifts or money if forwarded.
- **Instant Chat Messenger:** Attackers use chat messages to gather personal information.
- **Pop-up Windows:** Malicious pop-up ads leading to fake websites or malware downloads.
- **Impersonation using AI (Deepfake Videos, Voice Cloning):**
 - **Deepfake Videos:** Using AI/ML to create highly convincing fake videos of individuals for phishing or fraud.
 - **Voice Cloning:** Using AI/ML to synthesize a person's voice to impersonate them in phone calls or audio messages.
- **Impersonation on Social Networking Sites (SNS):**
 - Creating fake profiles to gather info or impersonate others.
 - **Angler Phishing:** Using fake social media accounts to target customers and service providers.
 - **Catfishing:** Creating fake online identities to deceive victims into relationships for personal or financial gain.

Perform Impersonation on Social Networking Sites



Identity Theft •

Identity theft is a crime in which an imposter steals your personally identifiable information such as name, credit card number, social security or driver's license numbers, etc. to commit fraud or other crimes. Attackers can use identity theft to impersonate employees of a target organization and physically access facilities

- Unfamiliar charges to your credit card that you do not recognize • Getting calls from the debit or credit fraud control department
- No longer receiving credit card, bank, or utility statements
- Charges for medical treatment or services you never received • No longer receiving electricity, gas, water, etc. service bills

Steps of stealing an identity

1. Gather targets information
 - Through e.g. bill from social networks, dumpster diving
 - Information include usually first and last name, date of birth, address, social security number, bank accounts, id card and passport numbers.
2. Fake identity proof: get fake IDs
 - Can be driving licence, ID card, etc...
 - E.g. using stolen bills you can claim the person lost driving license and get new one to an address you choose.
3. Fraud: spend money, unauthorized access, use ID for frauds, etc...
 - Can open new credit card accounts on the victim's name
 - Can sell identity information

4. Mobile-based Social Engineering Techniques

These target mobile devices.

- **Publishing Malicious Apps:** Attacker creates a malicious app (e.g., gaming app) and publishes it on app stores, disguised as legitimate.
- **Repackaging Legitimate Apps:** Attacker downloads a legitimate app, repackages it with malware, and uploads it to third-party app stores.
- **Fake Security Applications:** Attacker sends fake security alerts via mobile messages, tricking victims into downloading malicious apps that steal credentials.
- **SMiShing (SMS Phishing):** Using SMS text messages to lure users into downloading malware or visiting fraudulent websites.
- **QRJacking:** Exploiting QR Code Login methods to hijack sessions or gain unauthorized access. Attacker creates fake QR codes that redirect to malicious sites.

5. Social Engineering Countermeasures

Protecting against social engineering requires a multi-faceted approach focusing on education, policies, and technical controls.

General Countermeasures

- **Train Individuals on Security Policies:** Educate employees about social engineering techniques and threats.
- **Implement Proper Access Privileges:** Limit access to sensitive data on a need-to-know basis.
- **Presence of Incident Response Time:** Have a plan for reacting to social engineering attempts.
- **Availability of Resources to Authorized Users:** Ensure legitimate access to prevent frustration.
- **Scrutinize Information:** Verify information received, especially if it seems unusual.
- **Background Checks:** For employees, especially those with privileged access.
- **Anti-virus and Anti-phishing Defenses:** Use multi-layered security.
- **Implement Two-Factor Authentication (MFA/2FA):** Adds an extra layer of security for logins.
- **Adopt Documented Change Management:** Ensures changes are tracked and approved.
- **Regular Software Updates:** Keep OS and applications patched.
- **Implement Hardware Policy:** Rules for USB drives, etc.
- **Implement Software Policy:** Guidelines for software installation.
- **Verify Identity and Authorization:** Always verify caller/sender identity.
- **Implement Spam Filters:** To avoid infected emails.
- **Secure Communication Channels:** Use encrypted communication.

Specific Countermeasures

- **Password Policies:** Strong, unique, complex passwords; regular changes; lockout policies.
- **Physical Security Policies:** ID cards, visitor escorts, proper disposal of sensitive documents (shredding), surveillance.
- **Defense Strategy:** Security awareness campaigns, gap analysis, remediation strategies.
- **Identity Theft Countermeasures:**
 - Secure/shred documents.
 - Do not display personal info publicly.
 - Review credit card statements, monitor online banking.
 - Be cautious of links, unsolicited emails.
 - Implement 2FA on all accounts.
 - Use Wi-Fi for sensitive information only.
 - Install host security tools (firewall, antivirus).
 - Be cautious of medical info changes, complaints from colleagues, sudden drops in credit score.

- **Phishing Detection:**
 - Educate users on phishing campaigns.
 - Enable spam filters.
 - Hover over links to identify true destination.
 - Never provide credentials over the phone.
 - Check emails for salutations, spelling, grammar.
 - Use HTTPS-protected websites.
 - Implement MFA (especially against whaling).
 - Verify pictures/profiles using reverse image search.
 - Report suspicious activities.
 - Use anti-phishing tools/toolbars (Netcraft, PhishTank).
 - Audit phishing campaigns (OhPhish).
- **Voice Cloning Countermeasures:**
 - Be suspicious of unsolicited phone calls asking for sensitive info.
 - Verify caller identity through alternative channels.
 - Educate users about voice cloning risks.
 - Implement biometrics/advanced authentication.
 - Use anti-spoofing tech.
 - Secure communication channels (encrypted voice calls).
- **Deepfake Attack Countermeasures:**
 - Digital watermarking.
 - Blockchain technology to verify content authenticity.
 - Facial recognition tech to distinguish real from deepfakes.
 - Strong privacy measures.
 - User reporting mechanisms on social media platforms.
 - Train public/media to critically evaluate digital content.
 - Develop AI/ML tools to detect inconsistencies.
 - Establish ethical guidelines for AI developers.
 - Forensic techniques for analyzing artifacts.

- **Social Engineering:** Manipulating people to divulge information.
- **CIA Triad:** (Not directly from SE but always relevant) Confidentiality, Integrity, Availability.
- **Authority:** SE principle, obeying perceived superiors.
- **Consensus (Social Proof):** SE principle, doing what others do.
- **Scarcity:** SE principle, creating urgency about limited availability.
- **Urgency:** SE principle, encouraging immediate action.
- **Trust:** SE principle, building rapport to exploit.
- **Greed:** SE principle, luring with promises of gain.
- **Phishing:** Fraudulent emails/messages.
- **Spear Phishing:** Targeted phishing.
- **Whaling:** Phishing targeting executives.
- **Pharmishing:** Redirecting to fake websites (DNS poisoning/host file modification).
- **Scareware:** Fake security software prompts.
- **Vishing:** Phishing via voice/VoIP.
- **SMiShing:** Phishing via SMS.
- **QRJacking:** Exploiting QR codes for session hijacking.
- **Impersonation:** Pretending to be someone else.
- **Piggybacking/Tailgating:** Following authorized person into restricted area.
- **Dumpster Diving:** Searching trash for info.
- **Honey Trap:** Online deception for info.
- **Baiting:** Luring with attractive offers (e.g., infected USBs).
- **Quid Pro Quo:** Promise for info exchange.
- **Elicitation:** Subtly extracting info in conversation.
- **Deepfake:** AI-generated fake video/audio.
- **Voice Cloning:** AI to synthesize voices.
- **Angler Phishing:** Catfishing on social media for info.
- **Catfishing:** Creating fake online identity.
- **Identity Theft:** Stealing personal info for fraudulent purposes.
- **2FA/MFA:** Two-Factor/Multi-Factor Authentication (countermeasure).
- **DNSSEC:** Countermeasure against DNS spoofing/pharmishing.
- **Netcraft/PhishTank:** Anti-phishing tools/resources.

- **OhPhish:** Phishing simulation platform for auditing.
- **Human Factor:** The weakest link in security.
- **Security Awareness Training:** Essential countermeasure.